INCIDENT WALL

Day 4 adds five more real incidents

Ten cards from Days 2 and 3 are already on the wall. When you have worked on a card, stick it on the wall and add a sticky note: **The control that would have helped:**

- **1** The code that went to a chatbot (Samsung, 2023)
- **2** The regulator's decision (Italy, December 2024)
- **3** Eleven days without a cap (Agent loop, 2025)
- **4** The pull request that reached the release (Amazon Q Developer, July 2025)
- **5** The assurance review with invented references (Deloitte Australia, 2025)

At 16:10 the wall comes down. Each pair takes one card and writes the control and who at CSOB should own it.

CARD 1 | Samsung, 2023

The code that went to a chatbot

What was reported

- Samsung Electronics' semiconductor division began allowing staff to use ChatGPT on 11 March 2023, according to Economist Korea.
- The same outlet reported on 30 March 2023 three cases of staff entering company material into it: two with source code and one with meeting content. One engineer was reported to have pasted the source code of a program that handles semiconductor equipment measurement data, to get help fixing an error.
- On 2 May 2023 Bloomberg reported a Samsung memo banning generative AI tools on company devices. As reported, the memo said engineers had accidentally leaked internal source code by uploading it to ChatGPT.
- Reporting differs on the month (March in the Korean reports, April in the report of the memo). Samsung did not say what the code contained, and no misuse of the data was reported.

The question for your pair

Nobody broke into anything. Which rule or control would have applied before the first paste, and who at CSOB would have been asked?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Economist Korea (30 March 2023) as summarised by NHIMG; Bloomberg (2 May 2023) via Business Standard, Business Insider and Forbes Australia; The Register (2 May 2023).

CARD 2 | Italy, December 2024

The regulator's decision

What was reported

- On 20 December 2024 the Italian data protection authority (the Garante) fined OpenAI 15 million euros over ChatGPT.
- It said OpenAI had processed users' personal data to train ChatGPT without first identifying an adequate legal basis, and had breached the transparency principle and its information obligations to users. It also ordered a six-month public information campaign in Italian media.
- Reports describe it as the first significant GDPR fine against a major generative AI provider in Europe. The investigation began in March 2023, when the Garante imposed a temporary limit on ChatGPT in Italy.
- OpenAI called the fine disproportionate and said it would appeal.

The question for your pair

The finding was about training a model, not about a bank. What is the same question for a bank's own agent: what is the legal basis for each use of personal data, and where is it written down?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Garante announcement, 20 December 2024, as reported by AP (via accesswdun.com), Bloomberg Law, The Hacker News, Lewis Silkin (14 January 2025) and Syrenis.

CARD 3 | Agent loop, 2025

Eleven days without a cap

What was reported

- An engineer, Teja Kusireddy, published an account in autumn 2025 of a multi-agent research pipeline that ran in a loop for about eleven days and produced a bill of about 47,000 US dollars.
- Accounts say the agents coordinated over the A2A protocol and kept asking each other for clarification, with no orchestrator to decide when the work was done. Health checks passed throughout and nobody noticed until the invoice arrived.
- Commentary afterwards agrees the missing control was a cap on spend or iterations, and that an anomaly alert on cost would have shortened the eleven days.
- This is a self-reported account that was widely repeated, not an independently investigated case. Retellings differ on the number of agents (two or four).

The question for your pair

The dashboards showed activity and no errors. What would the first useful signal have been, and is an alert enough, or does something have to be able to stop it?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Kusireddy's account as repeated by DEV Community posts, Waxell (Logan Kelly), the Rapid Flow newsletter and PolicyLayer. Not independently verified.

CARD 4 | Amazon Q Developer, July 2025

The pull request that reached the release

What was reported

- A person using the handle lkmanka58 submitted a pull request to Amazon's open-source repository for the Amazon Q Developer extension for VS Code, containing a prompt telling the assistant to delete local files and cloud resources.
- The change was merged and shipped in version 1.84.0 on 17 July 2025.
- AWS's security bulletin said the code was incorrectly formatted and did not run as intended, that no customer resources were affected, and that it revoked and replaced credentials and released version 1.85.0. Reports put the extension at close to a million installations.
- Reports differ on when AWS acknowledged the issue (19 July in one account, 23 July in others). The formatting flaw, not a control, stopped the instructions from running.

The question for your pair

The thing that was changed was a prompt, and it was changed by a stranger. Which line of a configuration record would have shown it, and who reviews a change to a prompt?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: AWS security bulletin (19 July 2025) as reported by AWS Insider (25 July 2025); CyberInsider; TechRepublic (28 July 2025); Red Hot Cyber (25 July 2025).

CARD 5 | Deloitte Australia, 2025

The assurance review with invented references

What was reported

- Deloitte Australia was paid about 440,000 Australian dollars by Australia's Department of Employment and Workplace Relations for an "independent assurance review" of the automated penalty system in the welfare compliance framework. The 237-page report was published in July 2025.
- In August a university researcher, Chris Rudge, reported that it contained fabricated references, including a quotation attributed to a federal court judgment and sources that did not exist.
- A revised version published in October removed them and disclosed that a generative AI tool (Azure OpenAI) had been used. The department said the substance and recommendations were unchanged, and that Deloitte agreed to repay the final instalment of the contract.
- Deloitte said the matter had been resolved directly with the client.

The question for your pair

A report said something reassuring. What would you ask for before relying on it, and who checks the checker?

Write your control on a sticky note, then stick this card on the Incident Wall.

Sources: Associated Press (7 October 2025) via CTV News, KSAT and The Republic; City AM (8 October 2025); YourStory.